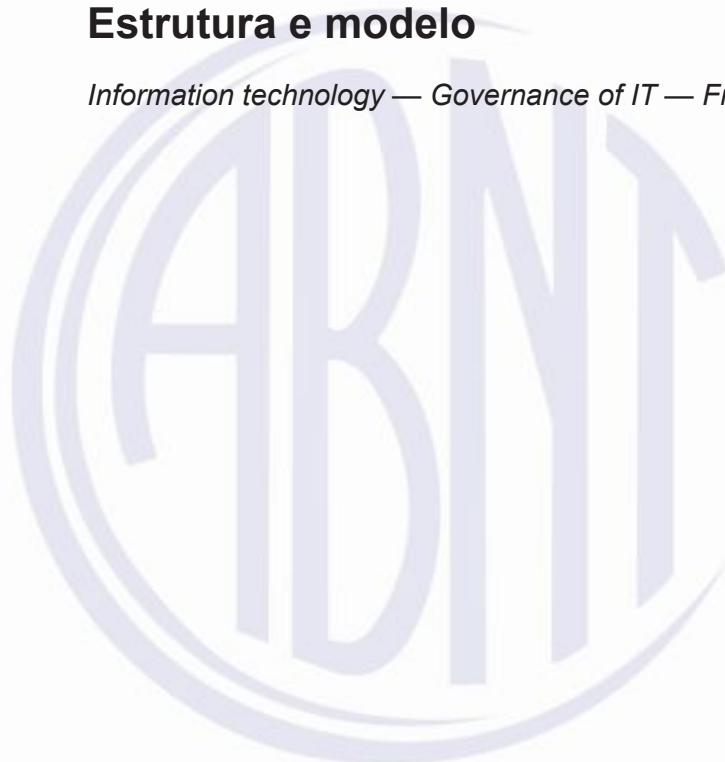

**Tecnologia da informação — Governança de TI —
Estrutura e modelo**

Information technology — Governance of IT — Framework and model



ICS 35.020



ASSOCIAÇÃO
BRASILEIRA
DE NORMAS
TÉCNICAS

Número de referência
ABNT ISO/IEC TR 38502:2026
13 páginas

© ISO/IEC 2017 - © ABNT 2026



© ISO/IEC 2017

Todos os direitos reservados. A menos que especificado de outro modo, nenhuma parte desta publicação pode ser reproduzida ou utilizada por qualquer meio, eletrônico ou mecânico, incluindo fotocópia e microfilme, sem permissão por escrito da ABNT, único representante da ISO no território brasileiro.

© ABNT 2026

Todos os direitos reservados. A menos que especificado de outro modo, nenhuma parte desta publicação pode ser reproduzida ou utilizada por qualquer meio, eletrônico ou mecânico, incluindo fotocópia e microfilme, sem permissão por escrito da ABNT.

ABNT

Rua Conselheiro Nebias, 1.131

01203-002 - São Paulo - SP

Tel.: + 55 11 3017-3600

abnt@abnt.org.br

www.abnt.org.br

Sumário

Página

Prefácio Nacional	iv
Introdução	v
1 Escopo	1
2 Referências normativas	1
3 Termos e definições	1
4 Modelo e estrutura	2
4.1 Modelo de governança de TI	2
4.1.1 Responsabilidades e responsabilização do órgão de governança	2
4.1.2 Tarefas de governança	3
4.1.3 Responsabilidades e responsabilizações dos gestores	4
4.1.4 Aplicabilidade do modelo	4
4.2 Relação entre governança e gestão de TI	4
4.3 Elementos-chave de uma estrutura de governança de TI	5
5 Orientação sobre a aplicação do modelo	7
5.1 Responsabilidades do órgão de governança	7
5.1.1 Geral	7
5.1.2 Órgãos de governança e mecanismos de supervisão	7
5.2 Formulação e supervisão de estratégias	8
5.2.1 Geral	8
5.2.2 Papel do órgão de governança na formulação da estratégia	8
5.3 Delegação	8
5.3.1 Geral	8
5.3.2 Delegação pelo órgão de governança	9
5.4 Responsabilidades dos gestores	9
5.4.1 Geral	9
5.4.2 Papel dos gestores	10
5.5 Governança e controle interno	10
5.5.1 Geral	10
5.5.2 Estabelecimento de controle interno	11
Anexo A (informativo) Princípios para a boa governança de TI	12
Bibliografia	13

Figuras

Figura 1 – Modelo de governança de TI	3
Figura 2 – Principais elementos de uma estrutura de governança para TI	5

Prefácio Nacional

A Associação Brasileira de Normas Técnicas (ABNT) é o Foro Nacional de Normalização. As Normas Brasileiras, cujo conteúdo é de responsabilidade dos Comitês Brasileiros (ABNT/CB), dos Organismos de Normalização Setorial (ABNT/ONS) e das Comissões de Estudo Especiais (ABNT/CEE), são elaboradas por Comissões de Estudo (CE), formadas pelas partes interessadas no tema objeto da normalização.

Os Documentos Técnicos internacionais adotados são elaborados conforme as regras da ABNT Diretiva 3.

A ABNT chama a atenção para que, apesar de ter sido solicitada manifestação sobre eventuais direitos de patentes durante a Consulta Nacional, estes podem ocorrer e devem ser comunicados à ABNT a qualquer momento (Lei nº 9.279, de 14 de maio de 1996).

Os Documentos Técnicos ABNT, assim como as Normas Internacionais (ISO e IEC), são voluntários e não incluem requisitos contratuais, legais ou estatutários. Os Documentos Técnicos ABNT não substituem Leis, Decretos ou Regulamentos, aos quais os usuários devem atender, tendo precedência sobre qualquer Documento Técnico ABNT.

Ressalta-se que os Documentos Técnicos ABNT podem ser objeto de citação em Regulamentos Técnicos. Nestes casos, os órgãos responsáveis pelos Regulamentos Técnicos podem determinar as datas para exigência dos requisitos de quaisquer Documentos Técnicos ABNT.

O ABNT ISO/IEC TR 38502 foi elaborado no Comitê Brasileiro de Tecnologias da Informação e Transformação Digital (ABNT/CB-021), pela Comissão de Estudo de Gestão e Governança de TI (CE-021:004.040). O Projeto foi submetido à Consulta Nacional no período de 12.03.2026 a 13.04.2026.

O ABNT ISO/IEC TR 38502 é uma adoção idêntica, em conteúdo técnico, estrutura e redação, ao ISO/IEC TR 38502:2017, que foi elaborado pelo *Joint Technical Committee Information Technology* (ISO/JTC 1), *Subcommittee IT service management and IT governance* (SC 40).

O Escopo em inglês do ABNT ISO/IEC TR 38502 é o seguinte:

Scope

This document provides guidance on the nature and mechanisms of governance and management together with the relationships between them, in the context of IT within an organization.

The purpose of this document is to provide information on a framework and model that can be used to establish the boundaries and relationships between governance and management of an organization's current and future use of IT.

Introdução

A medida de sucesso de qualquer investimento no uso de tecnologia da informação (TI), seja em novas iniciativas ou em operações em andamento, é o benefício que ele traz para a organização que realiza o investimento.

Os benefícios do investimento em TI normalmente não decorrem diretamente da própria TI, adquirida ou suportada. Em vez disso, os benefícios realizados são resultado de mudanças nas atividades de negócios possibilitadas pelo uso da tecnologia para atender às necessidades ou aos requisitos organizacionais. As organizações precisam de estratégias e acordos de suporte para TI que maximizem o valor desses investimentos enquanto gerenciam os riscos associados ao uso de TI. Os riscos incluem aspectos como a falha em fornecer os recursos necessários, a falha dos negócios em obter os benefícios necessários e o impacto na organização de falhas de TI que levam à interrupção dos negócios, violação de obrigações, não *compliance* regulatório, falhas de segurança, perda de dados, tempo de indisponibilidade etc.

Um dos desafios para o investimento organizacional em TI é assegurar que tais decisões de investimento e aquisição sejam baseadas em estratégias de negócio, prioridades e necessidades de negócios. Convém que os responsáveis pela governança da organização, portanto, tenham supervisão e envolvimento adequados nas decisões relacionadas ao uso de TI nos negócios, para assegurar que tais decisões sejam baseadas em estratégias de negócios, apetite por riscos, prioridades e necessidades. Convém que o esforço necessário para obter os benefícios esperados seja identificado e compreendido.

A ABNT NBR ISO/IEC 38500^[1] reconhece que o equilíbrio adequado entre demanda e oferta de TI é um requisito de boa governança e gestão, que precisa ser conduzido a partir do topo de uma organização. O objetivo da ABNT NBR ISO/IEC 38500 é fornecer orientação para o órgão de governança das organizações ao avaliar, direcionar e monitorar o uso de TI em suas organizações.

Há evidências de confusão no mercado em relação ao uso do termo *governança* quando se aplica à TI. Por exemplo, muitas vezes há uma aplicação inadequada do termo *governança* a *sistemas de gestão, estruturas de controle e sistemas de informação* que não são, em si mesmos, governança, mas que são resultados e facilitadores necessários para uma governança eficaz. Como resultado, muitas vezes há confusão sobre os respectivos papéis de governança e gestão, e isso tem dificultado o desenvolvimento de orientações consistentes em relação à governança e à implementação efetiva de práticas de governança.

Este documento foi desenvolvido para esclarecer a distinção entre os conceitos de governança e gestão em relação à TI. Ele fornece um modelo que ilustra a relação entre governança e gestão, identifica as responsabilidades associadas a cada um e orienta sobre o uso nas organizações de TI.



Tecnologia da informação — Governança de TI — Estrutura e modelo

1 Escopo

Este documento fornece orientação sobre a natureza e os mecanismos de governança e gestão, juntamente com as relações entre eles, no contexto de TI dentro de uma organização.

O objetivo deste documento é fornecer informações sobre uma estrutura e um modelo que podem ser usados para estabelecer os limites e as relações entre governança e gestão do uso atual e futuro de TI por uma organização.

Este documento fornece orientação para:

- órgãos de governança;
- gestores que trabalham dentro da autoridade e responsabilização estabelecidas pela governança;
- conselheiros ou aqueles que auxiliam na governança de organizações de todos os tamanhos e tipos; e
- desenvolvedores de normas nas áreas de governança e gestão de TI.

2 Referências normativas

Não há referências normativas neste documento.

3 Termos e definições

Para os efeitos deste documento, aplicam-se os termos e definições da ABNT NBR ISO/IEC 38500 e os seguintes.

A ISO e a IEC mantêm as bases de dados terminológicos para uso em normalização nos seguintes endereços:

- IEC *Electropedia*: disponível em <https://www.electropedia.org/>
- ISO *Online Browsing Platform*: disponível em <https://www.iso.org/obp>

3.1

estrutura de governança

estratégias, políticas, estruturas de tomada de decisão e responsabilização por meio das quais os acordos de governança da organização operam

3.2

controle interno

políticas, procedimentos, práticas e estruturas organizacionais projetados para fornecer garantia razoável de que os objetivos de negócios serão alcançados e que os eventos indesejados serão prevenidos ou detectados e corrigidos

3.3

sistema de gestão

conjunto de elementos inter-relacionados ou interativos de uma organização para estabelecer políticas, objetivos e processos para alcançar esses objetivos

Nota 1 de entrada: Um sistema de gestão pode abordar uma única disciplina ou várias disciplinas.

Nota 2 de entrada: Os sistemas de gestão operam dentro das estratégias, estruturas, responsabilidades e responsabilizações especificadas na estrutura de governança da organização.

[FONTE: ABNT NBR ISO 9000:2015, 3.5.3, modificada – As notas de entrada foram modificadas.]

3.4

apetite por riscos

quantidade e tipo de riscos que uma organização está disposta a buscar ou reter

[FONTE: ISO *Guide* 73:2009, 3.7.1.2]

4 Modelo e estrutura

4.1 Modelo de governança de TI

4.1.1 Responsabilidades e responsabilização do órgão de governança

O órgão de governança é responsável e responsabilizado pelo uso atual e futuro de TI em uma organização, como parte de sua responsabilidade geral pela governança organizacional.

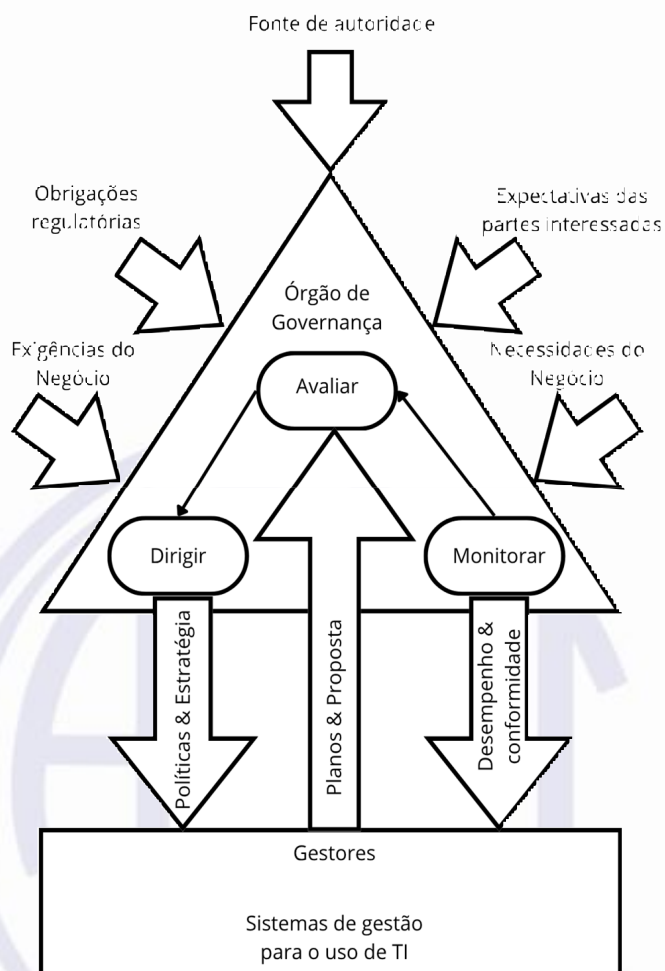


Figura 1 – Modelo de governança de TI

A autoridade, responsabilidade e responsabilização do órgão de governança dependerão da fonte de autoridade, como o acordo legislativo sob o qual opera. O nível de autoridade acordado e os limites do escopo da organização geralmente serão documentados. Dependendo do tamanho, tipo de organização e estrutura legislativa aplicável à organização, isso será feito na forma de uma constituição ou carta para a organização, ou um simples acordo entre as partes.

Em muitas empresas públicas, o órgão de governança é um conselho, por exemplo, conselho de administração. Em algumas jurisdições é utilizada uma estrutura de dois níveis, com conselho de supervisão e conselho executivo.

4.1.2 Tarefas de governança

A ABNT NBR ISO/IEC 38500^[1] recomenda que o órgão de governança governe o uso de TI por meio das tarefas de:

- Avaliar;
- Dirigir;
- Monitorar.

As tarefas de avaliação, direção e monitoramento são realizadas em estreita cooperação entre o órgão de governança e os gestores para permitir que o órgão de governança direcione e controle o uso de TI para cumprir os objetivos de negócios.

Ao desempenhar atividades de governança, convém que o órgão de governança leve em conta as obrigações regulatórias e as expectativas legítimas das partes interessadas em suas decisões, bem como o impacto do ambiente de negócios, incluindo exigências e necessidades de negócios.

4.1.3 Responsabilidades e responsabilizações dos gestores

Os gestores são responsáveis por assegurar o alcance dos objetivos da organização dentro das estratégias e políticas estabelecidas pelo órgão de governança. Os gestores prestam contas ao órgão de governança pelas responsabilidades atribuídas a eles.

As organizações podem operar por meio de uma hierarquia gerencial, com o CEO tendo responsabilidade geral e com os outros gestores da organização relatando direta ou indiretamente, conforme apropriado. Em algumas organizações, os gerentes executivos nomeados podem fazer parte do órgão de governança.

4.1.4 Aplicabilidade do modelo

O modelo de governança de TI descrito nesta Seção também pode ser utilizado para considerar os requisitos de governança em organizações nas quais não existe um órgão de governança formal, como um conselho de administração. Isso pode incluir organizações governamentais, onde a autoridade, a responsabilidade e a responsabilização estão dentro da estrutura política do governo. Nessas situações, a autoridade e a responsabilidade pela governança podem ser delegadas diretamente a um ou mais executivos da organização. Geralmente, será o CEO (ou equivalente) da organização que exercerá as responsabilidades do órgão de governança. Em pequenos negócios, o mesmo indivíduo pode assumir o papel de órgão de governança e CEO.

4.2 Relação entre governança e gestão de TI

Os principais elementos da relação entre governança e gestão de TI, conforme refletidos no modelo, são os seguintes:

- a) **Responsabilidades do órgão de governança.** Os membros do órgão de governança são responsáveis pela governança de TI e prestam contas pelo uso eficaz, eficiente e aceitável de TI dentro da organização;
- b) **Formulação e supervisão de estratégias.** A governança fornece os meios pelos quais o órgão de governança estabelece a direção da organização em relação ao uso de TI e monitora o estado da organização e o desempenho de seus gestores no alcance dos resultados requeridos;
- c) **Delegação.** Aspectos da governança de TI podem ser desempenhados por gestores quando tiverem a responsabilidade apropriada atribuída a eles pelo órgão de governança, juntamente com a autoridade delegada;
- d) **Responsabilidades dos gestores.** Os gestores são responsáveis por atingir os objetivos estratégicos organizacionais de acordo com as estratégias e políticas de uso de TI estabelecidas pelo órgão de governança; e
- e) **Governança e controle interno.** A governança eficaz de TI requer o estabelecimento de um sistema eficaz de controle interno como parte dos sistemas de gestão da organização.

Cada um desses elementos é discutido na Seção 5: Orientação sobre a aplicação do modelo.

4.3 Elementos-chave de uma estrutura de governança de TI

Convém que os sistemas de gestão de TI de uma organização e seu uso de TI sejam baseados em uma estrutura de governança estabelecida para a organização.

A estrutura de governança atual será determinada pela própria organização e dependerá do tamanho e função da organização e das decisões do órgão de governança quanto aos limites de responsabilidade, mas convém que os elementos-chave sejam conforme mostrados na Figura 2. A área sombreada mostra os elementos de gestão associados.

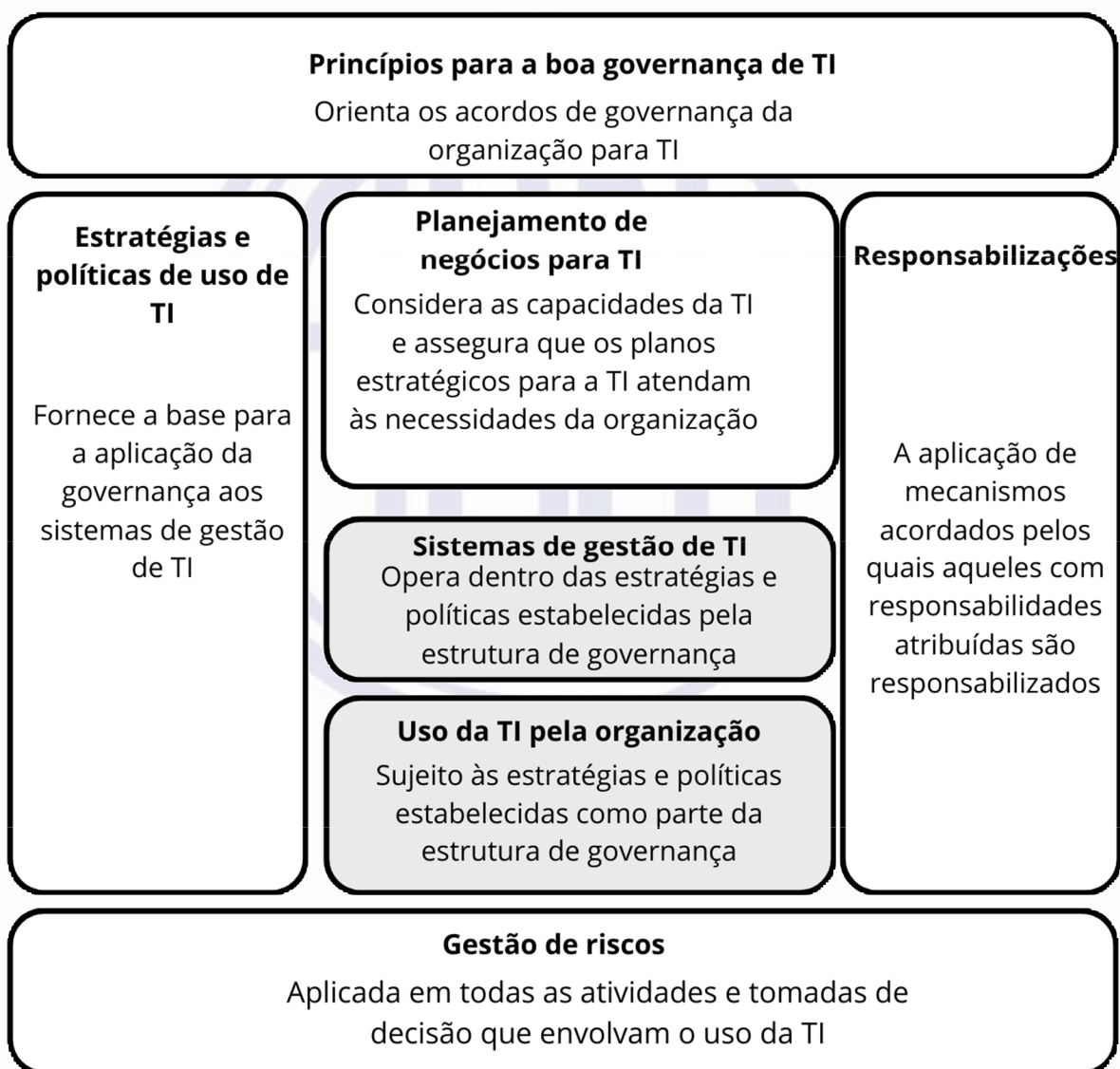


Figura 2 – Principais elementos de uma estrutura de governança para TI

Convém que os principais elementos de uma estrutura de governança para TI envolvam:

- Princípios para a boa governança de TI.** Convém que a estrutura de governança seja baseada nos princípios para uma boa governança de TI, conforme descrito na ABNT NBR ISO/IEC 38500 e no Anexo A deste documento. Convém que os princípios orientem como as organizações estabelecem os mecanismos de governança para o uso de TI.

- b) **Estratégias e políticas de uso de TI.** Convém que as estratégias e políticas de uso de TI estabelecidas pelo órgão de governança e comunicadas aos gestores forneçam a base para a aplicação da governança aos sistemas de gestão da organização. Embora baseadas, em parte, em requisitos obrigatórios estabelecidos por legislação e regulamentos em diferentes jurisdições, ou por diretrizes de políticas para organizações do setor público, convém que as estratégias e políticas abordem os requisitos específicos da organização estabelecidos por órgãos de governança e gestores. Convém que as estratégias e políticas que consideram os princípios de comportamento descritos na ABNT NBR ISO/IEC 38500 sejam definidas e comunicadas, e que os resultados sejam monitorados. Eles podem incluir:
- Objetivos de negócios para o uso de TI;
 - Prioridades e alocação de recursos;
 - Nível de autoridade e direitos de tomada de decisão, incluindo quais direitos de tomada de decisão são reservados ao órgão de governança;
 - Acordos necessários para a tomada de decisões, com base em estratégias e políticas acordadas para o uso de TI, incluindo responsabilidades, limites, autoridade, acordos de exceção e acordos de relatórios;
 - Apetite por riscos relacionado ao uso de TI e requisitos específicos de controle; e
 - Políticas que estabelecem os comportamentos necessários em relação ao uso de TI.
- c) **Planejamento de negócios para TI.** Convém que os processos de planejamento de negócios levem em consideração as capacidades atuais e futuras da TI para assegurar que os planos estratégicos de TI satisfaçam as necessidades atuais e contínuas da estratégia de negócios da organização. Isso inclui inovações de negócios habilitadas pelo uso da TI. O planejamento de negócios para TI é, portanto, parte integrante da estrutura de governança de TI de uma organização.
- d) **Gestão de riscos.** Convém que a estrutura de governança de TI envolva práticas robustas de gestão de riscos em todas as atividades e decisões relacionadas à TI. Convém que a gestão de riscos para o uso de TI seja baseada na aplicação dos processos de gestão de riscos da organização.
- e) **Responsabilizações.** Convém que os mecanismos que estabelecem como os responsáveis serão responsabilizados sejam claramente estabelecidos e acordados. Isso pode incluir, por exemplo, a avaliação contínua do desempenho (tanto desempenho quanto conformidade) das estratégias, planos e unidades de negócios de TI em toda a organização.
- f) **Sistemas de gestão para TI.** Convém que os sistemas de gestão de TI operem dentro das estratégias e políticas estabelecidas pelo órgão de governança para alcançar os objetivos estratégicos e operacionais da organização. Isso inclui sistemas que tratam da demanda e da oferta de TI por unidades de negócios internas, unidades especializadas de TI ou fornecedores externos e serviços utilitários. A responsabilidade pela implementação de sistemas de gestão para atingir os objetivos das organizações é dos gestores da organização.
- g) **Uso de TI pela organização.** O foco de uma estrutura de governança para TI é o uso da TI pela organização. Convém que o uso da TI para atender às necessidades do negócio esteja sujeito às estratégias e políticas estabelecidas como parte de uma estrutura de governança, bem como aos sistemas de gestão de TI da organização.

Convém que a estrutura de governança permita que os gestores atuem no dia a dia com o máximo de autonomia possível. A governança requer o desenvolvimento de valores e propósitos compartilhados, estabelecendo a direção e fornecendo recursos e autoridade delegada para permitir que os gestores atuem com autonomia e capacidade de resposta adequada em ambientes em mudança.

5 Orientação sobre a aplicação do modelo

5.1 Responsabilidades do órgão de governança

5.1.1 Geral

Os membros do órgão de governança são responsáveis pela governança de TI e são responsabilizáveis pelo uso eficaz, eficiente e aceitável de TI dentro da organização. [4.2 a)]

A autoridade, responsabilidade e responsabilização do órgão de governança pelo uso eficaz, eficiente e aceitável da TI surgem de sua responsabilidade geral pela governança da organização.

O foco principal do papel do órgão de governança na governança de TI é assegurar que a organização obtenha valor dos investimentos em TI enquanto gerencia riscos.

5.1.2 Órgãos de governança e mecanismos de supervisão

- a) Convém que o órgão de governança estabeleça mecanismos de supervisão para governança de TI que sejam apropriados ao nível de dependência de negócios em relação à TI.
- b) Convém que o órgão de governança tenha uma compreensão clara da importância da TI para as estratégias de negócios da organização, bem como o risco estratégico potencial para a organização do uso da TI. Convém que o nível de atenção que um órgão de governança dá à TI seja baseado nesses fatores.
- c) O órgão de governança pode estabelecer um subcomitê para auxiliá-lo a supervisionar o uso de TI pela organização de um ponto de vista estratégico. A necessidade de um subcomitê dependerá da importância da TI para a organização e seu tamanho.
- d) Convém que o órgão de governança assegure que seus membros e mecanismos de governança associados (como comitês de auditoria, risco e TI) tenham o conhecimento e a compreensão necessários do uso de TI e tendências e direções futuras de TI, bem como a autoridade apropriada para lidar com suas responsabilidades.
- e) Convém que o órgão de governança monitore a eficácia dos mecanismos de governança de TI, exigindo processos como auditoria e avaliações independentes para obter garantia de que a governança é eficaz. Por exemplo, convém que o órgão de governança assegure que haja cobertura de auditoria adequada dos processos de gestão, controle e governança de riscos relacionados à TI como parte da abordagem de auditoria.

5.2 Formulação e supervisão de estratégias

5.2.1 Geral

A governança fornece os meios pelos quais o órgão de governança define a direção da organização no uso de TI e monitora o estado da organização e o desempenho de seus gestores na obtenção dos resultados necessários. [4.2 b)]

Em geral, o órgão de governança atua para orientar a organização por meio de formulação da estratégia e da supervisão do desempenho dos gestores na implementação da estratégia. Em muitas organizações, isso requer que o órgão de governança trabalhe e seja aconselhado por gerentes executivos. Juntos, convém que eles tenham uma visão clara de como a TI pode ser melhor utilizada para o benefício da organização, tanto no presente quanto no futuro.

5.2.2 Papel do órgão de governança na formulação da estratégia

- a) Convém que o órgão de governança que trabalha e é aconselhado pelos gerentes executivos forneça liderança no desenvolvimento de estratégias para obter valor do uso de TI.
- b) Convém que o órgão de governança aprove a estratégia de negócios da organização para TI, levando em consideração as implicações da estratégia para atingir os objetivos de negócios e quaisquer riscos associados que possam surgir.
- c) Convém que o órgão de governança assegure que o ambiente externo e interno da organização seja monitorado e analisado regularmente para determinar se há necessidade de análise crítica e, quando apropriado, revisar a estratégia de TI e quaisquer políticas associadas. Isso inclui as necessidades e expectativas de seus clientes, a situação competitiva, seus pontos fortes, fracos e oportunidades, novas tecnologias, demandas regulatórias, mudanças políticas, previsões econômicas e fatores sociológicos.
- d) Convém que o órgão de governança assegure que as políticas sejam desenvolvidas para orientar o comportamento organizacional. Convém que tais políticas apoiem a realização dos objetivos de negócios, incluindo os requisitos de legislação e regulamentos obrigatórios. Outros requisitos serão baseados nas melhores práticas e orientarão a organização em termos de gestão de riscos ou melhorias na eficiência e eficácia.
- e) Convém que o órgão de governança assegure que existam mecanismos para esclarecer e interpretar objetivos, estratégias e políticas à medida que surgem questões emergentes.
- f) Convém que o órgão de governança entenda a agilidade dos negócios para quaisquer mudanças importantes propostas como parte da estratégia de negócios para TI e assegure que haja um compromisso e capacidade dentro da organização para realizar as mudanças necessárias.

5.3 Delegação

5.3.1 Geral

Aspectos da governança de TI podem ser assumidos por gestores, se tiverem a responsabilidade adequada atribuída pelo órgão de governança, juntamente com a autoridade delegada. [4.2 c)]

O órgão de governança atinge os objetivos da organização trabalhando em conjunto com os gestores da organização. Um órgão de governança pode delegar autoridade a um ou mais gestores sujeitos à constituição da organização e às leis e regulamentos aplicáveis pertinentes.

A governança de TI é exercida tanto pelo órgão de governança quanto pelos gestores. Em muitas organizações, a responsabilidade pelo uso da TI é atribuída aos gestores junto com a autoridade delegada para conduzir a organização e atingir os objetivos de negócios, ao invés de haver uma autoridade explicitamente delegada apenas para a TI.

Em princípio, não há restrições quanto ao que pode ser delegado aos gerentes executivos e o que continuará a ser desempenhado pelo órgão de governança. O órgão de governança permanece responsável pelo desempenho e conformidade da organização, mesmo quando aspectos de governança e gestão, como tomada de decisões, são delegados. Isso inclui o impacto do sucesso ou fracasso do uso da TI.

5.3.2 Delegação pelo órgão de governança

- a) O órgão de governança pode delegar aspectos da governança de TI a gestores da organização.
- b) Ao delegar a autoridade para a governança de TI, convém que o órgão de governança estabeleça:
 - Responsabilidades e limites de decisão claramente estabelecidos e acordados;
 - Autoridade proporcional com recursos apropriados; e
 - Mecanismos para assegurar a conformidade com as estratégias e políticas e que o desempenho no alcance dos objetivos seja monitorado e/ou avaliado.
- c) Convém que o órgão de governança assegure que aqueles a quem a autoridade é delegada tenham a competência necessária e que o órgão de governança mantenha a supervisão adequada das principais decisões.
- d) Convém que o órgão de governança determine e deixe claro quais decisões precisam ser encaminhadas ao órgão de governança, ao invés de serem tomadas pelos gestores sem consulta.
- e) Convém que o órgão de governança assegure que o grau de delegação de autoridade esteja claramente articulado em políticas de governança. Em relação à TI, o órgão de governança normalmente mantém o envolvimento em aspectos como:
 - Aprovação de objetivos, estratégias e políticas para o uso da TI;
 - Aprovação de investimentos significativos relacionados ao uso da TI;
 - Supervisão de programas e projetos com impacto relevante no negócio; e
 - Aprovação das principais práticas de gestão de riscos, como as relacionadas à segurança e continuidade dos negócios.
- f) Convém que o órgão de governança assegure que a adequação da autoridade delegada seja analisada criticamente, continuamente.

5.4 Responsabilidades dos gestores

5.4.1 Geral

Os gestores são responsáveis por alcançar os objetivos estratégicos organizacionais dentro das estratégias e políticas para o uso da TI estabelecidas pelo órgão de governança. [4.2 d)]

Os gestores são responsáveis por assegurar que a organização alcance os resultados exigidos dentro dos limites estabelecidos pelas estratégias e políticas de TI, estipuladas ou acordadas pelo órgão de governança. Os gestores prestam contas ao órgão de governança pelos resultados. As suas responsabilidades e autoridade são determinadas pelo órgão de governança. Em algumas jurisdições, podem existir requisitos específicos de responsabilização e de reporte aplicados a algumas funções organizacionais.

Os gestores são responsáveis pela implementação de estratégia e políticas, bem como pela implementação e supervisão dos sistemas de gestão necessárias para alcançar os objetivos estabelecidos pelo órgão de governança.

5.4.2 Papel dos gestores

- a) Convém que os gestores assegurem o alcance dos resultados requeridos para o negócio dentro das estratégias e políticas de uso de TI, estabelecidas pelo órgão de governança.
- b) Convém que os gestores implementem estratégias, políticas e sistemas de gestão para alcançar os objetivos de negócio estabelecidos pelos órgãos de governança. Isso pode incluir:
 - Desenvolver e divulgar políticas, diretrizes e normas para TI com base em princípios e políticas estipulados ou estabelecidos pelo órgão de governança;
 - Planejamento estratégico de TI como parte integrante do planejamento estratégico do negócio, se houver delegação de autoridade pelo órgão de governança;
 - Estabelecer mecanismos para gerenciar a demanda e a oferta de TI em apoio a iniciativas de mudança de negócio;
 - Estabelecer mecanismos para gerenciar a demanda e a oferta de TI para as operações de negócio existentes;
 - Aplicar a gestão de riscos (integrada ao sistema de gestão de riscos organizacionais) ao uso da TI;
 - Assegurar que os investimentos relacionados à TI sejam gerenciados como um portfólio com todo o escopo de atividades necessárias para obter valor de negócio; e
 - Monitorar e avaliar o desempenho e a conformidade organizacional e reportar ao órgão de governança.
- c) Convém que os gestores tomem decisões no contexto das estratégias e políticas estabelecidas pelo órgão de governança.

5.5 Governança e controle interno

5.5.1 Geral

A governança eficaz de TI requer o estabelecimento de um sistema eficaz de controle interno como parte dos sistemas de gestão da organização. [4.2 e)]

A governança eficaz de TI depende do estabelecimento de um sistema eficaz de controle interno como parte do estabelecimento de sistemas de gestão para apoiar a realização dos objetivos de negócios da organização.

Os gestores têm a responsabilidade de avaliar os riscos para a organização e implementar um sistema de controle interno apropriado. O órgão de governança estabelece políticas de controle interno, considerando o que é um risco aceitável para a organização, incluindo requisitos legais. A gestão de riscos é um elemento-chave do modelo de governança, uma vez que o risco precisa ser considerado durante a avaliação, direcionamento e monitoramento.

5.5.2 Estabelecimento de controle interno

- a) Convém que o órgão de governança estabeleça políticas de controle interno, levando em consideração o que é um risco aceitável para a organização. Convém que inclua o apetite por riscos relacionado ao uso de TI e requisitos específicos de controle.
- b) Convém que os gestores implementem sistemas de gestão que operem dentro das regras estabelecidas como parte de uma estrutura de governança que incorpore os princípios e práticas de governança e controle na organização.
- c) Convém que os requisitos específicos para o controle interno sejam baseados na consecução dos objetivos de negócios e nos requisitos regulamentares externos.
- d) Convém que sejam concebidas atividades de controle adequadas ao nível de risco, a fim de reduzir os riscos associados a cada processo ou projeto que possam afetar a capacidade da organização de alcançar seus objetivos de negócios.
- e) Convém que o sistema de controle interno derive da estrutura de governança, incluindo:
 - Definição clara das responsabilidades de TI dentro da organização. Isso inclui as responsabilidades, limites de responsabilidades, autoridade, responsabilização e acordos de relatórios;
 - Comunicação de informações pertinentes e confiáveis que permitam o exercício adequado das responsabilidades;
 - Gestão de riscos para identificar e analisar os riscos de TI em relação ao alcance dos objetivos e políticas de negócios da organização, e assegurar que existam procedimentos para gerenciar esses riscos; e
 - Monitoramento contínuo do sistema de controle interno, juntamente com análises críticas regulares sobre a forma como o controle interno de TI está operando.

Anexo A (informativo)

Princípios para a boa governança de TI

A ABNT NBR ISO/IEC 38500 descreve seis princípios para a boa governança de TI. Os princípios são aplicáveis à maioria das organizações. Este Anexo lista estes princípios e fornece detalhes básicos. Para obter mais informações, ver a ABNT NBR ISO/IEC 38500.

Os princípios expressam o comportamento preferido para orientar a tomada de decisões. A declaração de cada princípio se refere ao que convém que aconteça, mas não prescreve como, quando ou por quem os princípios seriam implementados, já que esses aspectos dependem da natureza da organização que os implementa. Convém que o órgão de governança requeira que esses princípios sejam aplicados.

Princípio 1 – Responsabilidade

Indivíduos e grupos dentro da organização compreendem e aceitam suas responsabilidades em relação tanto ao fornecimento quanto à demanda de TI. Aqueles com responsabilidade pelas ações também têm autoridade para executá-las.

Princípio 2 – Estratégia

A estratégia de negócios da organização leva em consideração as capacidades atuais e futuras da TI e os planos estratégicos de TI para satisfazer as necessidades atuais e contínuas da estratégia de negócios da organização.

Princípio 3 – Aquisição

As aquisições de TI são feitas por razões válidas, com base em análises apropriadas e contínuas, com uma tomada de decisão clara e transparente. Existe um equilíbrio apropriado entre benefícios, oportunidades, custos e riscos, tanto a curto quanto a longo prazo.

Princípio 4 – Desempenho

A TI é adequada para apoiar a organização, fornecendo os serviços, níveis de serviço e qualidade de serviço necessários para atender aos requisitos de negócios atuais e futuros.

Princípio 5 – Conformidade

A TI está em *compliance* com toda a legislação e regulamentação obrigatória. As políticas e práticas são claramente definidas, implementadas e aplicadas.

Princípio 6 – Comportamento humano

As políticas, práticas e decisões de TI demonstram respeito pelo comportamento humano, incluindo as necessidades atuais e em evolução de todas as pessoas envolvidas no processo.

Bibliografia

- [1] ABNT NBR ISO/IEC 38500, *Tecnologia da informação – Governança de TI para a organização*
- [2] ISO Guide 73, *Risk management – Vocabulary*
- [3] OECD Principles of Corporate Governance, OECD, 1999 and 2004
- [4] ABNT NBR ISO 9000:2015, *Sistemas de gestão da qualidade – Fundamentos e vocabulário*

